

Privacy & Compliance Framework

Privacy-by-Design Architecture for Blockchain-Based Credential Verification - v1.0, Prototype/Technical Design, Aug 2026

1. Executive Summary & Scope

EduProof is a blockchain-based credential issuance and verification platform connecting Issuers (institutions), Holders (students), and Verifiers (recruiters/employers). Traditional digital certificates are easy to forge and hard to verify independently. Blockchain enables tamper-evident verification, but public ledgers are persistent and readable by anyone, creating a privacy risk if personal data is written on-chain directly.

Core principle: Personal data stays off-chain. Cryptographic proof goes on-chain.

Scope covers credential issuance, on/off-chain storage, sharing, verification, revocation, versioning, and (where applicable) AI-assisted data extraction, across the Issuer → Holder → Verifier lifecycle.

2. Architecture & Data Flow

Layers: Frontend (React/Vite, role-based UI) → Web3 layer (ethers.js, wallet signing, hashing, QR access) → Blockchain (Solidity smart contract: issuer registry, credential hash, timestamp, status, version) → Off-chain storage (documents, personal data, metadata - specific tech not fixed in the prototype).

Issuance: Issuer → Frontend → Credential created → SHA-256 hash generated → wallet-signed transaction → Smart Contract → Blockchain (proof only). Document and personal details route separately to off-chain storage.

Verification: Verifier → Credential ID/QR → retrieve record → recompute hash → compare to on-chain proof → validate issuer → check status/version → result (VERIFIED / TAMPERED / UNAUTHORIZED ISSUER / REVOKED / SUPERSEDED / NOT FOUND).

3. Data Classification: On-Chain vs Off-Chain

OFF-CHAIN - PRIVATE DATA	ON-CHAIN - VERIFICATION PROOF
✓ Name, email, student ID, DOB	✓ Credential hash (SHA-256)
✓ Credential details & document (PDF)	✓ Issuer address & timestamp
✓ Detailed metadata, user profile	✓ Status, version, tx/event reference

Principle: store proof on-chain, not unnecessary personal information. Exact on-chain fields depend on final implementation and privacy requirements.

4. Core Mechanisms

Mechanism	How it works	What it does / doesn't prove
Cryptographic hashing	SHA-256 hash of canonical credential data, recorded on-chain	Proves integrity (tamper detection), not truthfulness of original data
Issuer authorization	Smart contract checks issuer wallet against authorized-issuer registry	Prevents impersonation; does not prevent a compromised authorized wallet from misuse
Verification	Recompute hash, compare on-chain, check issuer + status + version	QR is only an access convenience, not the security mechanism itself
Revocation	Status flag changed (Valid → Revoked); historical record preserved, not deleted	Invalidates a credential without erasing audit history
Version history	Updates create new versions instead of overwriting	Preserves traceability of corrections

Private keys must never be stored in or exposed to the frontend application.

5. Security Controls & Privacy-by-Design

Implemented in MVP

SHA-256 hashing; smart-contract access control; authorized issuer registry; wallet-based authorization; off-chain data separation; revocation; version history.

Production requirements (planned, not yet implemented)

Encrypted off-chain storage; formal key management (HSM); least-privilege backend access; audit logging; TLS/API security; rate limiting; backup/recovery; monitoring; input validation hardening.

Privacy-by-design principles applied

Data minimization · purpose limitation · storage separation · access control · transparency · security by default · auditability · lifecycle management.

6. Compliance Considerations

As an India-focused academic project, EduProof's design is discussed against general principles of India's Digital Personal Data Protection Act, 2023 (DPDP Act). This is an architecture discussion, not legal advice or a compliance certification.

Principle	EduProof Response	Status
Data minimization	Personal data off-chain; only proof on-chain	Architecture consideration
Transparency / notice	This document; in-app notices planned	Partially addressed
Security safeguards	Hashing + access control now; broader controls planned	In progress
Retention & user rights	Off-chain policy, access/correction tooling not yet built	Planned
Breach response	Process defined (§7); not yet operational	Planned

Important

On-chain records are persistent and cannot be deleted once written; EduProof addresses this by minimizing what is placed on-chain, not by promising blockchain deletion. Formal legal compliance requires a dedicated assessment of the deployed system, organization, and jurisdiction.

7. Key Risks, Limitations & Response

- Blockchain does not guarantee issuer truthfulness, and does not by itself make data private - hashing proves integrity, not fact.
- Risks not solved by blockchain alone: compromised issuer keys, malicious authorized issuers, frontend vulnerabilities, off-chain breaches, smart-contract bugs.
- Planned incident response: detect → contain → assess → notify (where required) → revoke affected credentials → recover → review.

8. Summary

EduProof applies a privacy-by-design architecture by keeping sensitive credential information separate from blockchain verification proofs, minimizing on-chain personal-data exposure while maintaining cryptographically verifiable credential integrity and lifecycle traceability.